



Vulnerability Assessment &
Penetration Testing (VAPT) Report

Salt Essential
Information Technology(PTY) Ltd

09th April 2025



Contents

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING	3
3	METHODOLOGIES USED.....	3
3.1	NMAP / ZENMAP	3
3.2	NESSUS	3
3.3	GREENBONE ENTERPRISE	3
	STAY ONE STEP AHEAD OF ATTACKERS.....	4
3.4	OWASP.....	4
3.5	BRUTE FORCE.....	5
	APPLICATIONS USED IN BRUTE FORCE INCLUDE:	5
3.6	FORTISCAN AND NUCLEI	5
3.7	0365 SPRAY TOOL	5
4	VIRTUAL SERVERS.....	5
4.1	DOMAIN CONTROLLER – 10.1.10.2	5
	▪ Vulnerability Assessment	5
4.2	SAGESAP SERVER – 10.1.10.5	8
	▪ Vulnerability Assessment	8
5	PORT MAPPING	12
5.1	41.63.241.133	13
6	PENETRATION TESTING:	13
6.1	197.188.229.121.2443 - FORTIGATE SSL VPN EXPOSURE	13
	▪ Scope:.....	13
	▪ Executive Summary:.....	13
	▪ Primary Assessment Objectives:	13
	▪ Key Findings:	13
	▪ Tools Used:.....	15
	▪ Scope Notes:	15
	▪ Final Reccommodations:.....	15
7	CYBER SECURITY ASSESSMENT:	15
7.1	OFFICE 365 PASSWORD SPRAY TEST	15
	▪ Objective:.....	15
	▪ Tested Methodologies:	15
	▪ Results:.....	16
	▪ Analysis:.....	16
	▪ Reccommodations:	16
	▪ Conclusion:	16
8	OUR FULL AND FINAL REPORTING CONCLUSION	17
9	AUDITORS	17



1 EXECUTIVE SUMMARY

The objective of this assessment was to identify security vulnerabilities, business logic flaws, and missing best security practices. The tests were conducted from the perspective of an attacker or malicious user, without causing any disruption to the functionality or performance of the application or network. Additionally, a comprehensive scan of the infrastructure was performed to simulate a real-world attack scenario, such as an internal network breach or exposure on a shared public subnet.

The assessment, including scans and brute-force testing, was carried out over ten business days to ensure a thorough and methodical audit. These scans also examined unidentified connectivity options, such as packet SYN requests.

Overall, Sautech is satisfied with the security devices, however, servers are still utilizing Windows Server 2012 and as such, many security flaws were identified. The End of Life of these operating systems were 2022. Recommendations are provided and discussed throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Domain Controller - 10.1.10.2 (via VPN)
- SageSap Server - 10.1.10.5 (via VPN)
- 41.63.241.133 - Natted Remote IP
- 197.188.229.121.2443 - Firewall (FortiGate)

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

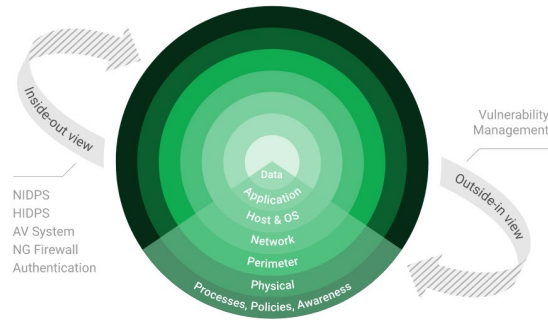
To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.

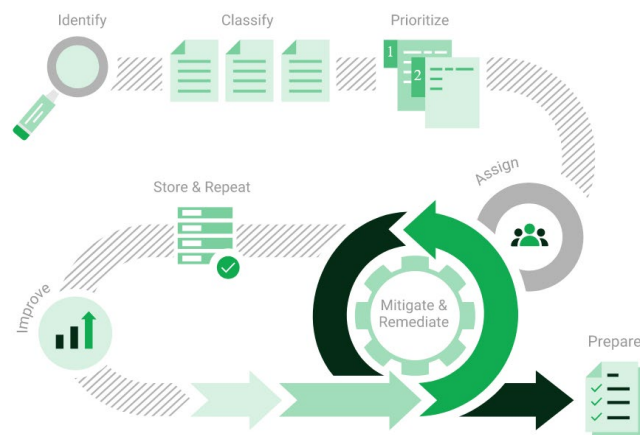
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



STAY ONE STEP AHEAD OF ATTACKERS

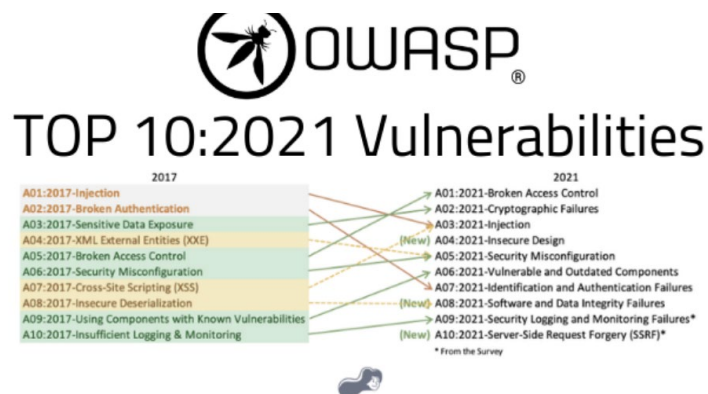
IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.



The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.

3.4 OWASP

The **Open Web Application Security Project (OWASP)** is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.





3.5 BRUTE FORCE

A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.

The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts.

Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers

Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 2.5 Million + Username and password combos are used to Brute force application like RDP, SSH etc.

3.6 FORTISCAN and NUCLEI

Why We Use **FortiScan** and **Nuclei**:

- Focused on Fortinet CVEs
- Designed to target Fortinet vulnerabilities with speed and accuracy
- Lightweight and updated constantly
- Reflects real-world attack patterns
- Safe for use in production-facing infrastructure
- Frequently updated with CVE signatures
- Provides a realistic attacker simulation
- Non-intrusive and safe for live systems

3.7 0365 SPRAY TOOL

The benefits of using the **0365 SPRAY TOOL** are:

- Simulates real-world attacks to test password hygiene and security posture
- Identifies weak accounts without causing massive disruption
- Validates lockout policies, MFA enforcement, and tenant resilience
- Helps IT teams strengthen identity protection policies with actionable data

4 VIRTUAL SERVERS

4.1 Domain Controller – 10.1.10.2

We have performed the following scan / attack on the Domain Controller Server namely:

▪ Vulnerability Assessment – TENABLE NESSUS

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



10.1.10.2



Vulnerabilities

Total: 51

SEVERITY	CVSS V3.0	VDR SCORE	IPSS SCORE	PLUGIN	NAME
HIGH	7.5	5.1	0.0398	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5	7.3	0.0056	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	5.3	-	-	45411	SSL Certificate with Wrong Hostname
LOW	3.7	4.5	0.9689	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	10736	DCE Services Enumeration
INFO	N/A	-	-	11002	DNS Server Detection
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	43829	Kerberos Information Disclosure
INFO	N/A	-	-	25701	LDAP Crafted Search Request Server Information Disclosure
INFO	N/A	-	-	20870	LDAP Server Detection
INFO	N/A	-	-	42410	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure



INFO	N/A	-	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	-	26917	Microsoft Windows SMB Registry : Nessus Cannot Access the Windows Registry
INFO	N/A	-	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)
INFO	N/A	-	-	10719	MySQL Server Detection
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	24786	Nessus Windows Scan Not Performed with Admin Privileges
INFO	N/A	-	-	10884	Network Time Protocol (NTP) Server Detection
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	-	10940	Remote Desktop Protocol Service Detection
INFO	N/A	-	-	31422	Reverse NAT/Intercepting Proxy Detection
INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	96982	Server Message Block (SMB) Protocol Version 1 Enabled (unauthenticated check)



INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	-	64814	Terminal Services Use SSL/TLS
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	135860	WMI Not Available
INFO	N/A	-	-	33139	WS-Management Server Detection
INFO	N/A	-	-	10150	Windows NetBIOS / SMB Remote Host Information Disclosure

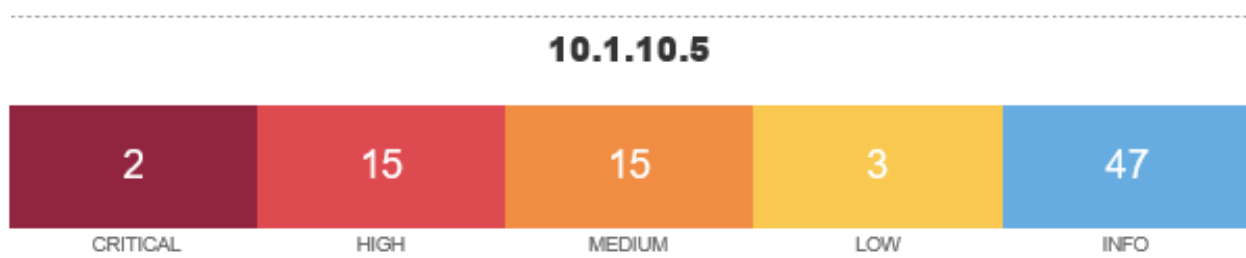
* indicates the v3.0 score was not available; the v2.0 score is shown

4.2 SageSap Server – 10.1.10.5

We have performed the following scan / attack on the SageSap Server namely:

- Vulnerability Assessment - TENABLE NESSUS

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



Vulnerabilities

Total: 82

SEVERITY	CVSS V3.0	VDR SCORE	EDSS SCORE	PLUGIN	NAME
CRITICAL	9.8	8.9	0.9743	197827	Apache Tomcat 8.5.0 < 8.5.51 multiple vulnerabilities
CRITICAL	10.0	-	-	73756	Microsoft SQL Server Unsupported Version Detection (remote check)



HIGH	8.6	4.7	0.0024	161181	Apache Tomcat 8.5.0 < 8.5.76
HIGH	7.5	6.7	0.0049	132418	Apache Tomcat 8.5.0 < 8.5.50
HIGH	7.5	4.4	0.0096	138097	Apache Tomcat 8.5.0 < 8.5.56
HIGH	7.5	3.6	0.9123	138574	Apache Tomcat 8.5.0 < 8.5.57 multiple vulnerabilities
HIGH	7.5	4.4	0.0029	144054	Apache Tomcat 8.5.0 < 8.5.60 multiple vulnerabilities
HIGH	7.5	5.9	0.002	147019	Apache Tomcat 8.5.0 < 8.5.63 multiple vulnerabilities
HIGH	7.5	3.6	0.0024	166807	Apache Tomcat 8.5.0 < 8.5.83
HIGH	7.5	4.4	0.0114	171656	Apache Tomcat 8.5.0 < 8.5.85
HIGH	7.5	4.4	0.006	186364	Apache Tomcat 8.5.0 < 8.5.96
HIGH	7.5	4.4	0.0854	160891	Apache Tomcat 8.5.38 < 8.5.79
HIGH	7.5	4.2	0.0876	35291	SSL Certificate Signed Using Weak Hashing Algorithm
HIGH	7.5	5.1	0.0398	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5	7.3	0.0056	65821	SSL RC4 Cipher Suites Supported (Bar Mitzvah)
HIGH	7.0	5.9	0.0005	132413	Apache Tomcat 8.5.0 < 8.5.49 multiple vulnerabilities
HIGH	7.0	6.7	0.9331	136807	Apache Tomcat 8.5.0 < 8.5.55
MEDIUM	6.5	4.2	0.0013	197847	Apache Tomcat 8.5.0 < 8.5.66
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	6.3	4.4	0.0004	192043	Apache Tomcat 8.5.0 < 8.5.99 multiple vulnerabilities
MEDIUM	6.1	3.0	0.0051	180192	Apache Tomcat 8.5.0 < 8.5.93
MEDIUM	5.3	3.6	0.0054	194472	Apache Tomcat 8.5.0 < 8.5.64 multiple vulnerabilities
MEDIUM	5.3	1.4	0.1554	152183	Apache Tomcat 8.5.0 < 8.5.68
MEDIUM	5.3	6.1	0.8556	182811	Apache Tomcat 8.5.0 < 8.5.94 multiple vulnerabilities



MEDIUM	5.3	-	-	12085	Apache Tomcat Default Files
MEDIUM	5.3	-	-	57608	SMB Signing not required
MEDIUM	5.3	-	-	45411	SSL Certificate with Wrong Hostname
MEDIUM	4.3	1.4	0.0012	197819	Apache Tomcat 8.5.0 < 8.5.58
MEDIUM	4.3	2.2	0.0013	173256	Apache Tomcat 8.5.0 < 8.5.86
LOW	3.7	1.4	0.0015	159462	Apache Tomcat 8.x < 8.5.78 Spring4Shell CVE-2021-43980
LOW	3.7	4.5	0.9689	83875	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
LOW	N/A	-	-	178943	Apache Tomcat SEOL (8.5.x)
INFO	N/A	-	-	39446	Apache Tomcat Detection
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	10736	DCE Services Enumeration
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	22319	MSRPC Service Detection
INFO	N/A	-	-	108761	MSSQL Host Information in NTLM SSP
INFO	N/A	-	-	69482	Microsoft SQL Server STARTTLS Support
INFO	N/A	-	-	10144	Microsoft SQL Server TCP/IP Listener Detection
INFO	N/A	-	-	10674	Microsoft SQL Server UDP Query Remote Version Disclosure
INFO	N/A	-	-	42410	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure
INFO	N/A	-	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)



INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	-	66334	Patch Report
INFO	N/A	-	-	10940	Remote Desktop Protocol Service Detection
INFO	N/A	-	-	31422	Reverse NAT/Intercepting Proxy Detection
INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	45410	SSL Certificate ' <u>commonName</u> ' Mismatch
INFO	N/A	-	-	83298	SSL Certificate Chain Contains Certificates Expiring Soon
INFO	N/A	-	-	42981	SSL Certificate Expiry - Future Expiry
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	-	96982	Server Message Block (SMB) Protocol Version 1 Enabled (uncredentialed check)
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided



INFO	N/A	-	-	64814	Terminal Services Use SSL/TLS
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	135860	WMI Not Available
INFO	N/A	-	-	33139	WS-Management Server Detection
INFO	N/A	-	-	11422	Web Server Unconfigured - Default Install Page Present
INFO	N/A	-	-	10150	Windows NetBIOS / SMB Remote Host Information Disclosure

* indicates the v3.0 score was not available; the v2.0 score is shown

5 PORT MAPPING - NMAP

Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

5.1 Domain Controller – 10.1.10.2

Nmap Output	Ports / Hosts			Topology	Host Details	Scans
	Port	Protocol	State	Service	Version	
●	53	tcp	open	domain	Simple DNS Plus	
●	80	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)	
●	88	tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2025-04-08 13:42:48Z)	
●	135	tcp	open	msrpc	Microsoft Windows RPC	
●	139	tcp	open	netbios-ssn	Microsoft Windows netbios-ssn	
●	389	tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: rflaun.local, Site: Default-First-Site-Name)	
●	445	tcp	open	microsoft-ds	Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: RFLAUN)	
●	2000	tcp	open	tcpwrapped		
●	3306	tcp	open	mysql	MySQL (unauthorized)	
●	3389	tcp	open	ms-wbt-server	Microsoft Terminal Services	
●	5060	tcp	open	tcpwrapped		
●	49152	tcp	open			
●	49153	tcp	open			
●	49154	tcp	open			
●	49155	tcp	open			

Remote Operating System Detection:

- Used Port: 53/tcp (open)
- Used Port: 80/tcp (open)
- Used Port: 88/tcp (open)
- Used Port: 135/tcp (open)
- Used Port: 139/tcp (open)
- Used Port: 445/tcp (open)
- Used Port: 2000/tcp (open)
- Used Port: 3306/tcp (open)
- Used Port: 3389/tcp (open)



- Used Port: 5060/tsp (open)
- Used Port: 49152/tsp (open)
- Used Port: 49153/tsp (open)
- Used Port: 49154/tsp (open)
- Used Port: 49155/tsp (open)

5.2 41.63.241.133

	Port	Protocol	State ▼	Service	Version
	53	tcp	open	domain	
	80	tcp	open	http	

Remote Operating System Detection:

- Used Port: 53/tsp (open)
- Used Port: 80/tsp (open)

6 PENETRATION TESTING:

6.1 197.188.229.121.2443 - FortiGate SSL VPN Exposure

▪ Scope:

Client: rflaun.com.na

Conducted by: Sautech Cyber Security Division

Target: <https://197.188.229.121:2443/login>

Purpose: Security Assessment of External VPN Exposure

▪ Executive Summary:

Sautech conducted a White-box penetration test on the client's FortiGate SSL VPN interface. Despite changing the default port to 2443, the VPN endpoint remained easily discoverable via tools like Nmap. This confirms that port obfuscation is not a sufficient defense mechanism.

The default administrative username 'admin' was still active, and our brute-force simulation using 100,000 passwords showed no signs of lockout, rate limiting or throttling mechanisms.

However, no successful logins were achieved, and known CVEs were effectively mitigated, showcasing **excellent patch management**.

Credit is due to the client for maintaining up-to-date firmware and blocking all known CVEs.

▪ Primary Assessment Objectives:

- Test Password strength
- Evaluate brute-force/spraying resistance
- Check for MFA enforcement
- Ensure stealth and avoid lockouts

▪ Key Findings:

1. Weak Administrative Account Configuration

The VPN interface remained accessible with the default 'admin' account using a custom port. While no successful logins were achieved, there were also no rate-limiting or lockout policies in place.



- **Brute Force Risk:** Without rate-limiting or lockout policies, attackers can continuously attempt to guess the password, increasing the likelihood of a successful brute force attack.
- **Default Credentials Exposure:** Keeping the default 'admin' account active poses a major risk, as attackers often target known defaults in automated scans.
- **No Deterrent:** The lack of login attempt restrictions fails to deter attackers, encouraging them to keep trying indefinitely.
- **Vulnerability Scanning:** Open and accessible interfaces on custom ports can still be discovered by attackers using port scanners, making "security through obscurity" ineffective.
- **Credential Stuffing Threat:** The absence of rate-limiting makes it easier for attackers to launch credential stuffing attacks using stolen password lists.
- **Monitoring Gaps:** If no alerts or monitoring are in place, repeated failed login attempts may go unnoticed, delaying detection and response.
- **Privileged Access Risk:** Since the exposed account is an admin, any compromise would result in full control of the VPN and potentially the internal network.
- **Policy Non-Compliance:** This setup likely violates basic cybersecurity policies and frameworks (like NIST, CIS, or ISO 27001), affecting audits and compliance posture.
- **Weak Security Posture Signal:** Even if no login was successful, the configuration signals a broader lack of security maturity, which could embolden attackers.
- **Future Exploits:** If the VPN software ever has a vulnerability affecting the login mechanism, an exposed and unprotected admin interface would be a prime target.

The VPN interface was available publicly, and although the port was changed to 2443, it was immediately identifiable using Nmap. The account 'admin' was still active.

Simulated FortiScan Output:

- [INFO] Starting brute-force against FortiGate SSL VPN
- [INFO] Target IP: 197.188.229.121 | Port: 2443 | User: admin
- [TEST] admin : summer2023!
- [TEST] admin : fortinet@123
- [TEST] admin : Password!
- [TEST] admin : admin2022!
- [TEST] admin : welcome1
- [FAIL] No valid credentials found after 100000 attempts

Impact: Allows unrestricted brute-force attempts and increases risk of credential compromise.

Result: No credentials were cracked, **which is positive.**

Recommendation:

- Rename or disable the 'admin' account
- Enforce lockout after failed logins
- Enforce strong password policies
- Require Multi-Factor Authentication (MFA)

2. Patch & Update Validation CVE Scanning Passed

Using Nuclei v3.4.0 with the latest Fortinet CVE templates (v10.1.5), we checked for vulnerabilities including:

- CVE-2018-13379
- CVE-2019-5591
- CVE-2020-12812

Scan Results:

- CVE-2018-13379 template loaded
- 14 Fortinet CVE templates tested
- No vulnerabilities detected

Manual testing also confirmed that endpoints such as /remote/fgt_lang?... were either hidden or patched.

Sautech notes that rflaun.com.na has clearly applied timely patches and maintains a strong perimeter defense.



Credit to rflaun.com.na: It's clear that firmware is up to date and that vulnerable endpoints are either patched or not exposed. Excellent patching practices observed.

3. No Lockout or MFA Detected

Brute-force tests using Hydra and custom scripts revealed:

- No lockout after 100,000 failed attempts
- No CAPTCHA or OTP triggered
- Admin account still fully accessible

Recommendation:

- Apply brute-force protection and rate limiting
- Enable MFA on all admin and VPN accounts
- Monitor all login events centrally
- Enable account lockouts
- Enforce OTP-based MFA
- Monitor login attempts in real time

Risk: High open to persistent brute-force attacks.

Tools Used:

Tool	Version	Purpose
Nmap	7.94	Port & service discovery
Hydra	9.4	Password Spraying & Credential brute-forcing
Nuclei	3.4.0	CVE scanning (Fortinet templates)
Custom FortiScan	Internal	Admin panel testing & brute-force simulation

Scope Notes:

Rule base configuration was not inspected, as this was outside the scope of the engagement. All tests were conducted externally, without post-authenticated or internal inspection.

Final Recommendations:

- Disable or rename the 'admin' account
- Implement lockout policy after multiple failed logins
- Enforce strong password policies (14+ characters, mixed type)
- Apply MFA to all admin/VPN accounts
- Apply account lockout policies after repeated login failures
- Continue timely firmware patching excellent work so far

7 CYBER SECURITY ASSESSMENT:

7.1 Office 365 Password Spray Test

Objective:

To evaluate the security posture of rflaun.com.na's Office 365 email accounts against brute-force and password spraying attempts.

Tested Methodologies:

A controlled password spray was performed against 10 Office 365 user accounts using a dictionary of 10,000 passwords.



Tools Configuration:

- Version: 3.0.4
- Domain: rflaun.com.na
- Spray: True
- Userfile: users.txt
- Passfile: passwords.txt
- Count: 1 password/spray
- Lockout: 15.0 minutes
- validate_module: getuserrealm
- spray_module: oauth2
- rate: 15 threads
- poolsize: 10000
- safe: 1 locked account
- timeout: 25 seconds
- output: results.txt

Users Tested:

- Dorian.Amwaandangi@rflaun.com.na
- Emilia.lipumbu@rflaun.com.na
- Glenn.Jagger@rflaun.com.na
- Judith.Mendonca@rflaun.com.na
- Julianus.Rukamba@rflaun.com.na
- Katrina.Thomas@rflaun.com.na
- Kauna.Nghiwilepo@rflaun.com.na
- Marina.Ishidhimbwa@rflaun.com.na
- Saija.lyambo@rflaun.com.na
- Susana.Horaes@rflaun.com.na

Results:

- The domain rflaun.com.na was confirmed to be using Office 365.
- No valid credentials were discovered.
- Account lockout was triggered after a single failed attempt, demonstrating effective security controls.
- The tool exited early due to the account lockout mechanism being activated.

Output snippet:

- [VALID] The following domain appears to be using O365: rflaun.com.na
- [LOCKED] Saija.lyambo@rflaun.com.na: administrator (Account locked.)
- [*] Valid Credentials: 0

Analysis:

rflaun.com.na has effectively configured Office 365 security:

- Strong account lockout policies
- Throttling against brute-force attacks
- No credential leaks during the assessment

Recommendations:

- Enforce password changes every 30 to 90 days.
- Require a minimum of 10-14 characters with uppercase, lowercase, numbers, and special characters.
- Maintain login monitoring and alerting via Microsoft 365 Defender.
- Ensure all users are protected with Multi-Factor Authentication (MFA).

Conclusion:

Based on the assessment, rflaun.com.na's Office 365 email configuration is secure and resistant to brute-force attacks. Sautech is satisfied with the current setup. Future improvements can further enhance this strong foundation.



8 OUR FULL AND FINAL REPORTING CONCLUSION

According to the reports, it is best to attach these separately from the main reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view, from External Testing, where open ports are not public but accessible only via VPN, these vulnerabilities become academic. However, we still recommend that the changes be implemented.

Six addendum reports are attached to this report and should be read as one document.

- Domain Controller (10.1.10.2) – Greenbone
- Domain Controller (10.1.10.2) – Nessus
- SageSap Server (10.1.10.5) – Greenbone
- SageSap Server (10.1.10.5) – Nessus
- SageSap Server (10.1.10.5) – OWASP
- (41.63.241.133) - OWASP

With the following test performed:

- Network scanning
- Unknown Firewall Bruteforce
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports , password complexity, lockout policies

We strongly recommend that the 'out of date' Windows Servers, be updated / upgraded as a matter of urgency, together with the other recommendations per audited sections above. Also noted, was external accessible DNS Service (TCP specific), meaning this not DNS remote lookups, but the TCP port 53 is used to perform domain updates and transfers, should this be needed, we recommend that this service is moved off the DC onto a DMZ network off domain.

9 AUDITORS

These audits were concluded over a period of 10 (ten) business days.

We hereby confirm that the above information is true and correct:

09th April 2025 – Krugersdorp, South Africa

Riaan van Jaarsveld
Certified - Ethical White Hat Hacker and Penetration Tester

Paul Coetzee
Assistant

Lukas Janse van Rensburg
Security Engineer